This is the third assignment for the Security course at LIACS. You can do this assignment **alone or in pairs**.

Submitting the assignment. In order to submit the assignment, you must first **join an "Assignment 3" group on BrightSpace by Thursday, May 7th 2026 at 23:59h at the latest. These groups are different from the ones from previous assignments. You must join one of these groups before this date to submit the assignment.** You can find the groups from the course's home page by clicking on "Course tools → Groups". If you do the assignment in pairs, *both members of the group must join the same group*.

Once the deadline for joining groups has passed, you will be added to the assignment on ANS, where you will be able to enter your answers. You must **submit the assignment on ANS by Thursday, May 14th 2026 at 23:59h**. Note that submitting the assignment on ANS means *submitting on behalf of the whole group*. Multiple people can work together on the assignment at the same time (ANS saves progress whenever you navigate away from a question), but the submission is final for everyone.

1 Motivation

The internet is a vital part of our lives. We use it for almost everything: Brightspace, search engines, social media, etc. Because of this universal presence, it is important that those technologies are secure. One way to check whether a service is secure is by pentesting it, i.e. by trying to attack it and look for known vulnerabilities.

In this assignment you will "pentest" some vulnerable websites: the goal will be to find some hidden "flags" by exploiting different vulnerabilities.

2 Connection instructions

In order to do this assignment you must be able to contact the vulnerable machine via HTTP(S). Since it is a bad idea to make vulnerable machines accessible to the internet, it is hosted in the internal LIACS network. To connect, follow these instructions:

1. On your own machine open a terminal and execute `ssh -D localhost:12345 sXXXXX@ssh.liacs.nl`. Replace `sXXXXX` with your LU student number. You will need to enter your LU password to connect.
   - If you are using Windows, you might get an error mentioning "Corrupted MAC on input". If that is the case you can either: (1) use Windows Subsystem for Linux (WSL)[1], which should not have this problem; or (2) follow the instructions in Appendix A of this document.
2. Look at the output of the command! If you see (near the top) the error message `bind [127.0.0.1]:12345: Address already in use`, then you need to (1) execute `exit` to close the ssh session (2) replace 12345 with another number between 1024 and 65535 and try again until you do not get the error. Use this new number whenever 12345 is mentioned in this document.
3. You do not need to do anything else in this ssh session, however **the target machine is only accessible as long as this session is open**. So keep the session open while you are actively working on the assignment, and close it afterwards.
4. Set up your browser to use this connection to reach the machine. The supported browser for this assignment is **Firefox**. See Appendix B for experimental instructions for chromium-based browsers.
   - Download the `websec.pac` file from BrightSpace.
   - Open Firefox
   - Open the *Settings*
   - Search for *Network Settings* and click on the *Settings* button to open the network configuration.
   - Select the *Automatic proxy configuration URL* option. In the field next to it, put `file:///` (notice the three slashes) followed by the complete path to the `websec.pac` file you created earlier. On Windows, this will look something like `file:///c:/Users/MyName/Downloads/websec.pac`; on Linux this will look something like `file:///home/user/Downloads/websec.pac` (do not add an additional `/` at the beginning, keep it to 3).
5. Confirm the settings and then connect to `https://websec2026.liacs.nl`. Note that this website is only accessible while the SSH session is active, as mentioned above.

[1] `https://learn.microsoft.com/en-us/windows/wsl/install`

6. If this is the first time that you access the assignment, create an account.
   - Use your name as username
   - User your university email when an email address is requested
   - **Do not re-use a password** that you commonly use to connect to services. Make up your own password for the assignment (and don't forget it!).
   - When asked for a registration code, enter `A32526`
   - One member of your team needs to create a team, where the name of the team is the same name as your BrightSpace group. The second member of your team can join the team of the other.

For future sessions, you need to remember to re-start the SSH session with the command above before trying to connect to the machine. You should not need to re-modify your network settings in-between sessions. Also, of course you will not need to re-create an account on the website, but you will need to login with the username and password you set up the first time.

Connection issues. If you can not manage to connect using the above instructions: we ask that you come to the lab sessions and ask the TAs for help. If that is impossible for you, write an email to the course email `security2026@liacs.leidenuniv.nl`.

3 Policy

While this assignment is about web vulnerabilities, participating in it does not give you authorization to do everything you want on the target machine, nor to attack other machines!

- **Only** access the servers that are described in the challenges.
- **Do not** try to exploit the CTFd platform, which we use as a central hub to access the different challenges.
- **Do not** use automated tools and/or vulnerability scanners that can cause heavy network loads e.g., nmap, sqlmap.
- **Do not** overload the target machine.
- **Do not** disrupt the work of other students that are using the target machine.

Deliberate breaking of these rules or attempts to do something other than solving the assignment on the target machine will result in your account being blocked, your grade changed (up to not issuing a grade for this assignment), and a report to the Board of Examiners.

4 Task

You interact with this assignment via the CTFd web interface. This is a web interface to manage "capture the flag" challenges, i.e. cybersecurity challenges in which participants try to find a hidden "flag". Once you create an account on the platform, you can see ten different challenges. These challenges will point you to different situation where your knowledge of security will allow you to find the hidden values ("flags") that we have created. Complete as many of these challenges as you can by finding the "flag" for each challenge. We don't tell you what the flags are, but you will recognize them when you find them.

Once you find a flag, you can enter it in CTFd to confirm that you found the correct value. This will tell you that you managed to find the expected exploit (or one that we did not expect!).

A note about HTTP. Due to technical limitations of our setup, the pages for the individual challenges are served over HTTP and not HTTPS (only the CTFd management interface is served over HTTPS). This is not ideal, as nowadays all websites should use HTTPS by default[2]. Because of that, your browser will show a warning when you connect to the individual challenges, and you will have to click on "Advanced → Accept the Risk and Continue" (or similar). *The usage of HTTP over HTTPS on the challenge webpage is not one of the vulnerabilities that we expect you to exploit or mention.* Each challenge relies on some other vulnerability that would still be present with HTTPS.

[2] Read `https://doesmysiteneedhttps.com/` if you are curious.

Your submission. For each challenge that you manage to successfully complete (i.e. you manage to find a valid flag), we ask you to describe: (1) what the vulnerability was; (2) how you exploited the vulnerability to find the flag; (3) what the flag was.

You will fill in these descriptions as answers to different exercises on **ANS**, once submissions open (one week before the deadline). We suggest that you do not wait for that moment but you start writing them down in your own notes while you are solving the exercises. *Note that completing the challenges on CTFd does not count as part of your submission, only what you enter in ANS does.*

4.1 Submission requirements

Your submission must abide to the following requirements (use this list as a checklist):

- ☐ For each completed challenge, you explain what the vulnerabilities were.
- ☐ For each achieved level, you explain how you exploited the aforementioned vulnerabilities to recover the flag. The explanations are clear and not missing any detail.
- ☐ For each completed challenge, you give the value of the flag that you found.
- ☐ Your explanations are **in English and clear**.

A Solving Windows "MAC" problems

If, when trying to connect via ssh to LIACS' network, you get an error mentioning "Corrupted MAC on input" (or similar), follow these steps *on your machine*:

1. Go to your user directory. If your name is Alice, it will be something like `C:/Users/Alice`. Note that `Users` might show up as something different depending on your system language.
2. If it does not exist yet, create a directory named `.ssh` (note the starting dot).
3. Using a text editor (e.g. VSCode or Notepad) create a file inside this `.ssh` directory named `config` (**and not** `config.txt`).
4. Write the following contents in the file, taking care to replace `XXXXXXXXX` with your student number.

```
Host ssh.liacs.nl
User sXXXXXXXXX
MACs hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,umac-128-etm@openssh.com
```

You should now be able to connect to LIACS' network.

B Chromium-based browsers

Chromium-based browsers do not allow to specify network configuration in their settings interface. Instead, you need to (1) download the `websec.pac` file from BrightSpace, or create it based on Appendix C; (2) start the browser from the command line, and add the option `--proxy-pac-url=file:///path/to/websec.pac`. Notice the 3 slashes at the start. On Windows, the path will look something like `file:///c:/Users/MyName/Downloads/websec.pac`; on Linux this will look something like `file:///home/user/Downloads/websec.pac` (do not add an additional `/` at the beginning, keep it to 3).

C Proxy file content

In order to connect to the assignment machine —which is hidden in the LIACS network— with Firefox, we need to first set up a local proxy that has access to that network, and then instruct Firefox to use it. The former step is done by connecting to the LIACS network with ssh and passing the `-D` option, which creates a local proxy that has access to the network. The easiest way to achieve the latter step, is with a Proxy Auto-Configuration (PAC) file. You can find the needed file on BrightSpace, as `websec.pac`. For reference, we report here its contents:

```
function FindProxyForURL(url, host){
    if ( dnsDomainIs(host,"MACHINENAME") ) {
        return "SOCKS5 127.0.0.1:12345" ;
    }
}
```

Where `MACHINENAME` should be replaced with `websec2026.liacs.nl`.